Clabs

Web Application Penetration Testing Report

December 2021

CREST. | PENTEST | BDO UNITED KINGDOM

Contents

1. EXECUTIVE SUMMARY 3
2. DOCUMENT CONTROL 4
3. SCOPE 5
4. HEADLINES 6
5. WEB APPLICATION PENETRATION TESTING ASSESSMENT RESULTS .. 7
6. RISK GRADING AND CVSS 17
7. METHODOLOGY 20
8. APPENDIX A - TOOLS USED 21

1. EXECUTIVE SUMMARY

Clabs ("Clabs") engaged BDO LLP ("BDO") to perform web application penetration testing against their infrastructure. The objective of the testing was to assess the security posture of Clabs's external exposed web application services to threats and to identify the potential areas of compromise.

Testing was conducted by BDO, between 19th November till the 8th December 2021, from the BDO Cyber Lab at BDO's corporate office at 55 Baker Street, London. The point of contact for the duration of the testing was Will Lee (W@celo.org) and Benjamin Speckien (Benjamin.Speckien@clabs.co).

During the course of the assessment, BDO identified multiple issues. The following subsections provide a high-level overview of the findings and suggested remediation.

The results of this penetration test have been graded with respect to the BDO's experience of testing other organisations in various services sectors. This grading is a subjective grading based on the team who performed this review.

The following table breaks down the issues which were identified by activity and severity of the technical risk:

Activity Type	Critical	High	Medium	Low
Web Application Penetration Testing	0	0	2	3

Web Application Penetration Testing

The web application penetration testing identified two (2) medium, three (3) low risk findings. The identified risks are summarised below:

- The majority of risks identified that some changes to the security configuration of the applications is required to meet best practice. These changes include the removal of support for insecure encryption ciphers, communication protocols, disabling software banners which disclose information regarding to the technology in use, and the modification of application elements and cookie security flags.
- The primary risk associated with these findings is that an attacker located between a client and the applications, could potentially capture encrypted traffic and decrypt its contents. This requires the client to be on a susceptible network such as public hotspots that could allow an attacker to initiate a Man-in-The-Middle (MiTM) attack.

During the course of the assessment, BDO identified multiple issues that require configuration changes or further analysis by Clabs. The following subsections provide a high-level overview of the findings and suggested remediation.

2. DOCUMENT CONTROL

2.1. CLIENT CONFIDENTIALITY

This document contains client confidential information and may not be copied without written permission.

2.2. PROPRIETARY INFORMATION

The content of this document should be considered proprietary information and should not be disclosed outside of Clabs and/or assigned personnel who would assist in remediation of observations.

BDO LLP gives permission to copy this report for the purposes of disseminating information within your organisation or any regulatory agency.

2.3. DOCUMENT HISTORY

Version	Author	Date	Comment
0.1	Richard Brown	16/12/2021	Initial draft
0.2	Brad Storan	17/12/2021	QA
0.3	Vijay Velu	17/12/2021	Director Review
0.4	Mike Stiglianese	20/12/2021	Partner Review
0.5	Richard Brown	20/12/2021	Draft Release
0.6	Rupert Sabale	16/02/2022	Final Review
1.0	Richard Brown	16/02/2022	Final Release

3. SCOPE

3.1. BACKGROUND

BDO performed web application penetration testing on Clabs's external exposed web services using a black and grey box testing approach.

3.2. OBJECTIVES

The focus of testing was to identify system, network and any application vulnerabilities that could lead to a loss of data integrity or unauthorised access. The techniques employed to test systems included both manual and automated methods. This included network and host mapping, vulnerability identification, and the testing of vulnerabilities to confirm their existence and level of risk.

The scope of the work for the penetration testing covered:

Base Location	URL
58 West Portal Ave PMB 729 San Francisco CA 94127	Api.transfer.celo.org
	Api.transferanalytics.celo.org
	Forno.celo.org
	Explorer.celo.org

Testing was conducted from the following location:

Testing Location	IP Address
BDO LLP, 55 Baker Street, London	212.161.9.187

3.3. CONSTRAINTS AND LIMITATIONS

Denial of Service (DoS) and account lock out attacks were explicitly out of scope of testing.

Note: the results of this assessment are applicable to the items in scope only as these were presented at the time. Results may be invalidated by later changes to the systems and by progress in information security research. Some tests were not performed due to potential business impact.

3.4. POST ASSESSMENT ACTIONS

Ensure that the testing account supplied to BDO “benjamin.speckien” has its credentials changed now that testing is completed. Additionally, remove the “bdouser” account from the user list of the transfer.celo application.

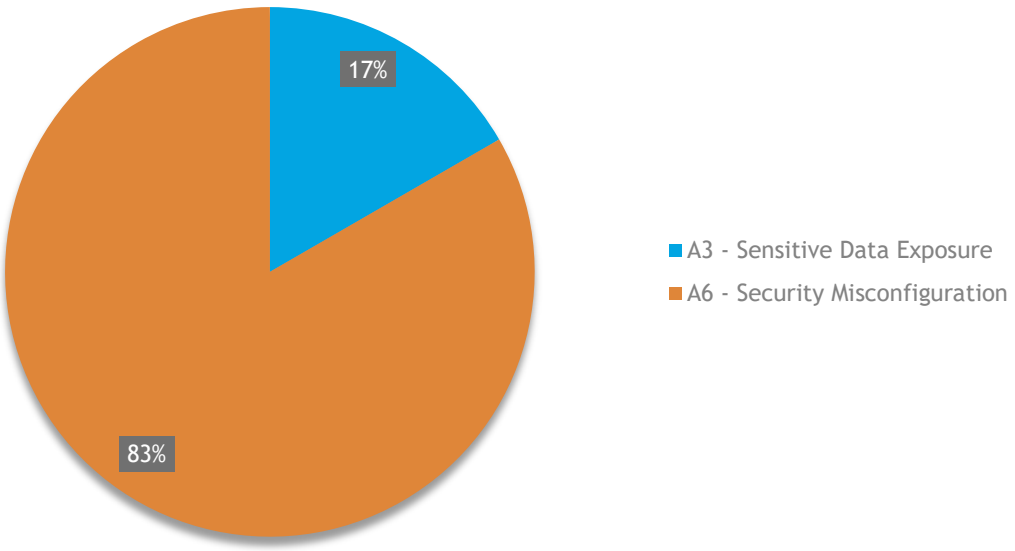
4. HEADLINES

All the issues identified during the assessment are listed below with a finding name and risk rating for each issue. The risk rating definitions and the vulnerability categorisations are included in 'Section 6'.

4.1. WEB APPLICATION PENETRATION TESTING HEADLINES

Detail	Reference	Risk	Status	OWASP Vulnerability Category
Weak SSL Cipher Suites Supported	CLABS-APP-1	Medium	Open	A6
Insecure TLS protocol in use	CLABS-APP-2	Medium	Open	A6
Insecure Cookie flags set	CLABS-APP-3	Low	Open	A6
Multiple information disclosure security issues	CLABS-APP-4	Low	Open	A3
Password field with autocomplete enabled	CLABS-APP-5	Low	Open	A6
Cacheable HTTPS responses	CLABS-APP-6	Low	Open	A6

4.1.1. DISTRIBUTION OF FINDINGS



OWASP Vulnerability Category	Findings
A3 - Sensitive Data Exposure	1
A6 - Security Misconfiguration	5

5. WEB APPLICATION PENETRATION TESTING ASSESSMENT RESULTS

5.1. WEAK SSL CIPHER SUITES SUPPORTED

Ref: CLABS-APP-1

Category: A6

CVE: CVE-2016-2183

Impact: Medium

Difficulty: Medium

CVSS: 5.4

Impacted Systems

URL: Port	URL: Port	Notes
api.transfer.celo.org:443	api.transferanalytics.celo.org:443	

5.1.1. DESCRIPTION

The applications support the use of SSL ciphers that offer medium strength encryption. BDO regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite. It is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network. Strong encryption should be enforced for all communications.

5.1.2. DETAIL

The following code extracts were captured by BDOs to evidence Weak SSL Cipher Suites Supported:

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Name                        Code          KEX       Auth    Encryption            MAC
----------------------      ----------    ---       ----    --------------------  ---
DES-CBC3-SHA                0x00, 0x0A    RSA       RSA     3DES-CBC(168)         SHA1
```

5.1.3. RISK

SSL issues could allow for an attacker decrypt information in transit allowing them to capture confidential information or launch MiTM attacks.

5.1.4. RECOMMENDATION

Reconfigure the affected application, if possible, to avoid use of medium strength ciphers.

5.1.5. ADDITIONAL INFORMATION

https://www.openssl.org/blog/blog/2016/08/24/sweet32/

https://sweet32.info

5.2. INSECURE TLS PROTOCOL IN USE

Ref: CLABS-APP-2

Category: A6

CVE: N/A

Impact: Medium

Difficulty: Medium

CVSS: 5.2

Impacted Systems

URL: Port	Notes
api.transfer.celo.org:443	

5.2.1. DESCRIPTION

TLS versions 1.0 and 1.1 have a number of cryptographic design flaws that potentially allow the decryption of encrypted traffic. Modern implementations of TLS 1.0/1.1 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible. As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

5.2.2. DETAIL

The following code extracts were captured by BDOs to evidence Insecure TLS protocol in use:

```
TLSv1.0 and 1.1 is enabled and the server supports at least one cipher.

TLSv1.0   enabled
TLSv1.1   enabled

Preferred TLSv1.1  128 bits  ECDHE-RSA-AES128-SHA          Curve 25519 DHE 253
Accepted  TLSv1.1  256 bits  ECDHE-RSA-AES256-SHA          Curve 25519 DHE 253
Accepted  TLSv1.1  128 bits  AES128-SHA
Accepted  TLSv1.1  256 bits  AES256-SHA
Accepted  TLSv1.1  112 bits  DES-CBC3-SHA
Preferred TLSv1.0  128 bits  ECDHE-RSA-AES128-SHA          Curve 25519 DHE 253
Accepted  TLSv1.0  256 bits  ECDHE-RSA-AES256-SHA          Curve 25519 DHE 253
Accepted  TLSv1.0  128 bits  AES128-SHA
Accepted  TLSv1.0  256 bits  AES256-SHA
Accepted  TLSv1.0  112 bits  DES-CBC3-SHA
```

5.2.3. RISK

Using outdated encryption could allow for attackers to decrypt data in transit and perform MiTM attacks, potentially leading to further compromise of information and/or devices.

5.2.4. RECOMMENDATION

Disable support for TLS version 1.0 and 1.1 and ensure that TLS version 1.2/1.3 is enabled

5.2.5. ADDITIONAL INFORMATION

https://tools.ietf.org/html/draft-ietf-tls-oldversions-deprecate-00

5.3. INSECURE COOKIE FLAGS SET

Ref: CLABS-APP-3

Category: A6

CVE: N/A

Impact: Low

Difficulty: Medium

CVSS: 3.4

Impacted Systems

URL: Port	URL: Port	Notes
api.transfer.celo.org:443	api.transferanalytics.celo.org:443	

5.3.1. DESCRIPTION

When the HttpOnly attribute is set on a cookie, then the cookie's value cannot be modified by client-side JavaScript. This removes the ability for client-side attacks, such as cross-site scripting, from accessing the cookies value. Increasing the difficulty of utilising this information by preventing them from trivially capturing the cookie's value via an injected script.

It is noted that some applications may require the ability for JavaScript to be able to access the values stored within cookies.

5.3.2. DETAIL

The following screenshots were captured by BDOs to evidence insecure cookie flags set:

Api.transfer.celo.org - CSRFToken - Request

```
GET /admin/accounts/customuser/ HTTP/2
Host: api.transfer.celo.org
Cookie: csrftoken=H24D7O7n2yKUy3jlX1WvnoRS8pMPmzcnaSks1VX9OzZkWfmyy3TuJZXQEm6s8ZUr;
sessionid=4v2nrdf75bbn7b8nchbt9vcdw5yuuf4d
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://api.transfer.celo.org/admin/login/?next=/admin/accounts/customuser/
Upgrade-Insecure-Requests: 1
...[SNIP]...
```

Api.transfer.celo.org - CSRFToken - Response

```
Content-Length: 28311
Strict-Transport-Security: max-age=15552000
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Referrer-Policy: same-origin
Set-Cookie: csrftoken=H24D7O7n2yKUy3jlX1WvnoRS8pMPmzcnaSks1VX9OzZkWfmyy3TuJZXQEm6s8ZUr; expires=Wed, 30
Nov 2022 11:49:25 GMT; Max-Age=31449600; Path=/; SameSite=Lax
Via: 1.1 google
Alt-Svc: clear

<!DOCTYPE html>

<html lang="en-us" >
<head>
<title>Select user to change | Django site admin</title>
...[SNIP]...
```

Api.transferanalytics.celo.org – CSRFToken - Request

```
GET /admin/login/?next=/admin/auth/user/add/ HTTP/2
Host: api.transferanalytics.celo.org
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate
...[SNIP]...
```

Api.transfer.celo.org – CSRFToken - Response

```
HTTP/2 200 OK
Date: Wed, 01 Dec 2021 11:49:03 GMT
Server: uvicorn
Content-Type: text/html; charset=utf-8
Expires: Wed, 01 Dec 2021 11:49:03 GMT
Cache-Control: max-age=0, no-cache, no-store, must-revalidate, private
Vary: Cookie, Origin
Content-Security-Policy: img-src 'self' www.google-analytics.com raw.githubusercontent.com
googleads.g.doubleclick.net; manifest-src 'self'; script-src 'self' www.google-analytics.com ssl.google-
analytics.com cdn.ampproject.org www.googletagservices.com pagead2.googlesyndication.com
*.cloudflare.com; worker-src 'self'; style-src 'self' *.cloudflare.com fonts.googleapis.com; base-uri
'self'; connect-src 'self' www.google-analytics.com; media-src 'self'; frame-ancestors 'self'; form-
action 'self'; default-src 'self'; font-src 'self' *.cloudflare.com fonts.gstatic.com data:; object-src
'self'
X-Frame-Options: DENY
Content-Length: 2222
Strict-Transport-Security: max-age=15552000
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Referrer-Policy: same-origin
Set-Cookie: csrftoken=kQbeRZVe50tfAafKROtPQB4gNDIPP5MBQKSePGLdvEYrJUIMnmNEFW7YTiKxrkjD; expires=Wed, 30
Nov 2022 11:49:03 GMT; Max-Age=31449600; Path=/; SameSite=Lax
Via: 1.1 google

...[SNIP]...
```

5.3.3. RISK

An attacker who is able to execute client-side script injection, could potentially capture the value of the cookie to use in additional attacks in order to hijack a user's session.

5.3.4. RECOMMENDATION

If the applications require legitimate client-side scripts within the applications to read or set a cookies value, the HttpOnly flag should be left disabled. However, if this is not required ensure it is enabled by including this attribute within the relevant Set-cookie directive.

5.4. MULTIPLE INFORMATION DISCLOSURE SECURITY ISSUES

Ref: CLABS-APP-4

Category: A3

CVE: N/A

Impact: Low

Difficulty: Low

CVSS: 3.2

Impacted Systems

URL: Port	URL: Port	Notes
api.transfer.celo.org:443	api.transferanalytics.celo.org:443	

5.4.1. DESCRIPTION

BDO were able to determine the type of proxy server in use by the applications as well as access administrative login interfaces for the Django service. This information can be used to narrow down potential vulnerability and exploits associated with the technology as well as provide an avenue of attack such as brute forcing.

5.4.2. DETAIL

The following code extracts were captured by BDOs to evidence Multiple information disclosure security issues:

```
api.transfer.celo.org:443
api.transferanalytics.celo.org:443

The proxy server type is: Uvicorn
```

The administrative login portals are publicly available for both applications:

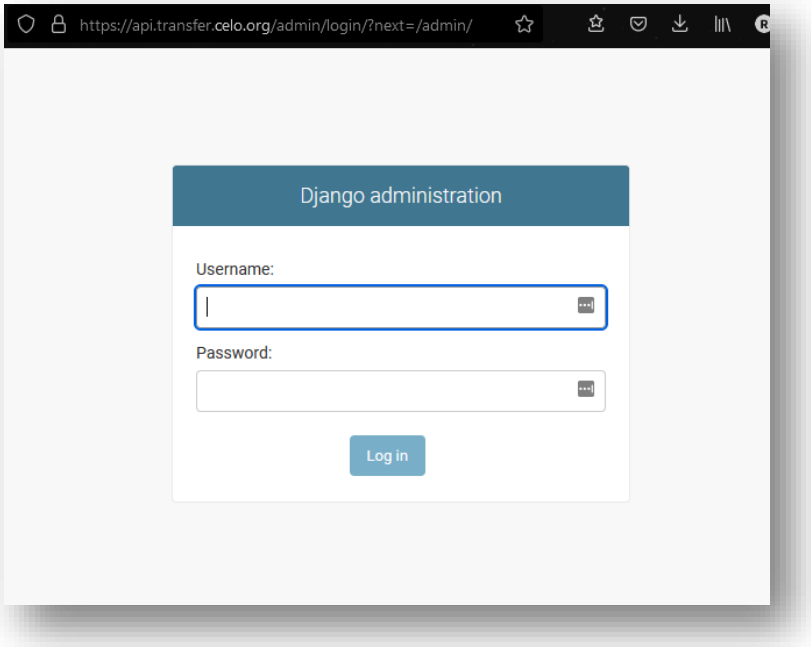


Figure 1 - Django administrative login portal

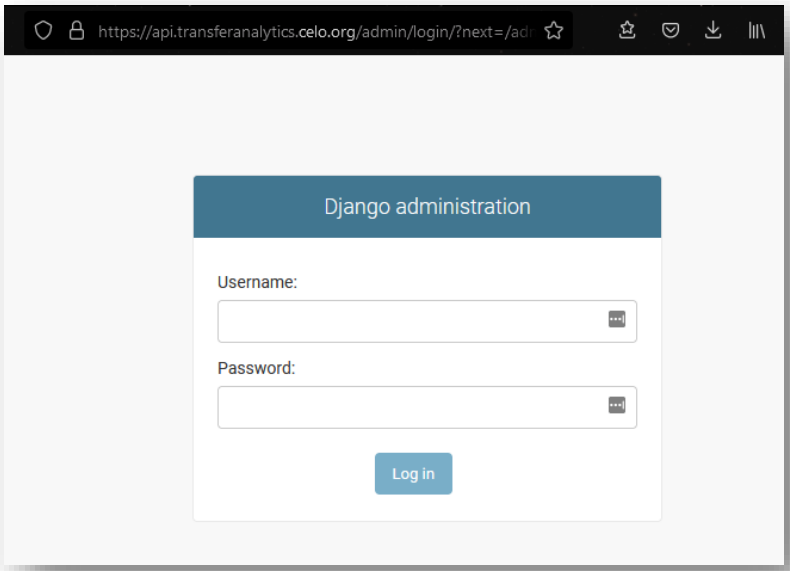


Figure 2 - Django administrative login portal

5.4.3. RISK

Disclosure of the technologies in use by the web application can aid an attacker in narrowing down potential vulnerabilities and exploits that could be used against it. Additionally, providing public access to administrative interfaces could allow an attacker to perform attacks such as brute forcing or utilise compromised credentials to access the administrative interface of the application.

5.4.4. RECOMMENDATION

Ensure that server header is removed from the applications responses

Disable public access or restrict access to the administration interface for the applications to IP addresses with a legitimate business need.

5.5. PASSWORD FIELD WITH AUTOCOMPLETE ENABLED

Ref: CLABS-APP-5

Category: A6

CVE: N/A

Impact: Low

Difficulty: Low

CVSS: 2.1

Impacted Systems

URL: Port	URL: Port	Notes
api.transfer.celo.org:443	api.transferanalytics.celo.org:443	

5.5.1. DESCRIPTION

Most browsers have the ability to store user credentials that are entered into HTML forms within the browser. This function can be configured by the user and also by applications that employ user credentials. If this is being used by the user, when credentials are entered by the user they are stored on their local computer and can be retrieved by the browser on future visits to the same application.

5.5.2. DETAIL

The following requests and responses were captured by BDOs to evidence password field with autocomplete enabled:

Api.transfer.celo.org - Request

```
GET /admin/login/?next=/admin/accounts/customuser/ HTTP/2
Host: api.transfer.celo.org
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Te: trailers
```

Api.transfer.celo.org - Response

```
HTTP/2 200 OK
Date: Wed, 01 Dec 2021 11:49:15 GMT
Server: uvicorn
Content-Type: text/html; charset=utf-8
Expires: Wed, 01 Dec 2021 11:49:15 GMT
Cache-Control: max-age=0, no-cache, no-store, must-revalidate, private
Vary: Cookie, Origin
...[SNIP]...


<form action="/admin/login/?next=/admin/accounts/customuser/" method="post" id="login-form"><input
type="hidden" name="csrfmiddlewaretoken"
value="BwdgoMZRIcyL45ol8yxNXQpDrhnZGWFS48bv8aJLr42S61wb5rr0b4rpTEGFgT0y">
...[SNIP]...
</label> <input type="password" name="password" autocomplete="current-password" required
id="id_password">
<input type="hidden" name="next" value="/admin/accounts/customuser/">
...[SNIP]...
```

Api.transferanalytics.celo.org - Request

```
GET /admin/login/?next=/admin/auth/user/add/ HTTP/2
Host: api.transferanalytics.celo.org
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Te: trailers
```

Api.transferanalytics.celo.org - Response

```
HTTP/2 200 OK
Date: Wed, 01 Dec 2021 11:49:03 GMT
Server: uvicorn
Content-Type: text/html; charset=utf-8
Expires: Wed, 01 Dec 2021 11:49:03 GMT
Cache-Control: max-age=0, no-cache, no-store, must-revalidate, private
Vary: Cookie, Origin
Content-Security-Policy: img-src 'self' www.google-analytics.com raw.githubusercontent.com
googleads.g.doubleclick.net; manifest-src 'self'; script-src 'self' www.google-analytics.com ssl.google-
analytics.com cdn.ampproject.org www.googletagservices.com pagead2.googlesyndication.com
*.cloudflare.com; worker-src 'self'; style-src 'self' *.cloudflare.com fonts.googleapis.com; base-uri
'self'; connect-src 'self' www.google-analytics.com; media-src 'self'; frame-ancestors 'self'; form-
action 'self'; default-src 'self'; font-src 'self' *.cloudflare.com fonts.gstatic.com data:; object-src
'self'
...[SNIP]...

<form action="/admin/login/?next=/admin/auth/user/add/" method="post" id="login-form"><input
type="hidden" name="csrfmiddlewaretoken"
value="RCElkmA1ajQoZkywpVqOSqmZVOVwZoBEnwlli3q0AXlA841yVtKDHLpH1tXeBD8G">
...[SNIP]...
</label> <input type="password" name="password" autocomplete="current-password" required
id="id_password">
<input type="hidden" name="next" value="/admin/auth/user/add/">
...[SNIP]...
```

5.5.3. RISK

The stored credentials can be captured by an attacker who gains control over the user's computer or their browser (Man-in-The-Browser). Furthermore, an attacker who finds a separate application vulnerability such as cross-site scripting may be able to exploit this to retrieve a user's browser-stored credentials.

5.5.4. RECOMMENDATION

To prevent browsers from storing credentials entered into HTML forms, include the attribute autocomplete="off" within the FORM tag (to protect all form fields) or within the relevant INPUT tags (to protect specific individual fields).

5.6. CACHEABLE HTTPS RESPONSES

Ref: CLABS-APP-6

Category: A6

CVE: N/A

Impact: Low

Difficulty: Low

CVSS: 2.1

Impacted Systems

URL: Port	URL: Port	Notes
api.transfer.celo.org:443	api.transferanalytics.celo.org:443	

5.6.1. DESCRIPTION

Browsers can store a local cached copy of the content received by the applications. Depending on the browser this can include HTTPS content. If sensitive information from the application is allowed to be cached then it could be retrieved by other users who have access to the same computer.

The CWE's for the findings are:

CWE-524: Information Exposure Through Caching, CWE-525: Information Exposure Through Browser Caching

5.6.2. DETAIL

The following request and responses were captured by BDOs to evidence password field with autocomplete enabled:

Api.transfer.celo.org - Request

```
GET / HTTP/1.1
Host: api.transfer.celo.org
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/95.0.4638.69 Safari/537.36
Connection: close
```

Api.transfer.celo.org - Response

```
HTTP/2 200 OK
Date: Wed, 01 Dec 2021 11:52:20 GMT
Server: uvicorn
Content-Type: text/html; charset=utf-8
Content-Security-Policy: default-src 'self'
X-Frame-Options: DENY
Content-Length: 604
Vary: Cookie, Origin
Strict-Transport-Security: max-age=15552000
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Referrer-Policy: same-origin
Via: 1.1 google
Alt-Svc: clear

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<meta http-equiv="X-UA-Compatible" content="ie=e
...[SNIP]...
```

Api.transferanalytics.celo.org – Request

```
GET / HTTP/2
Host: api.transferanalytics.celo.org
Cookie: csrftoken=yQ4Uu7c2PjHx3kzSbbY0RYya4MtCdxHomnHgELxAMot2JWjDcPkbwH0ftJMqItne;
sessionid=gfkqcwjbkmdqpnh90hpfmhxgnbgx9opk
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:94.0) Gecko/20100101 Firefox/94.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Te: trailers
```

Api. transferanalytics.celo.org – Response

```
HTTP/2 200 OK
Date: Wed, 01 Dec 2021 11:57:33 GMT
Server: uvicorn
Content-Type: text/html; charset=utf-8
Content-Security-Policy: img-src 'self' www.google-analytics.com raw.githubusercontent.com
googleads.g.doubleclick.net; manifest-src 'self'; script-src 'self' www.google-analytics.com ssl.google-
analytics.com cdn.ampproject.org www.googletagservices.com pagead2.googlesyndication.com
*.cloudflare.com; worker-src 'self'; style-src 'self' *.cloudflare.com fonts.googleapis.com; base-uri
'self'; connect-src 'self' www.google-analytics.com; media-src 'self'; frame-ancestors 'self'; form-
action 'self'; default-src 'self'; font-src 'self' *.cloudflare.com fonts.gstatic.com data:; object-src
'self'
X-Frame-Options: DENY
Content-Length: 576
Vary: Cookie, Origin
Strict-Transport-Security: max-age=15552000
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Referrer-Policy: same-origin
Via: 1.1 google
Alt-Svc: clear

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<meta http-equiv="X-UA-Compatible" content="ie=e
...[SNIP]...
```

5.6.3. RISK

An attacker with access to a user's computer could potentially retrieve any cached data stored within the users browser.

5.6.4. RECOMMENDATION

Ensure the applications web server returns the following HTTP headers in all responses containing sensitive content:

- Cache-control: no-store
- Pragma: no-cache

6. RISK GRADING AND CVSS

6.1. RISK GRADING

The technical findings arising from our review are graded according to the risk rating listed below. Overall, issues that are identified as High impact and that have a Low difficulty of exploitation should have maximum priority in terms of identifying a fix. On the other hand, issues that have a Low impact and a High difficulty to exploit require less urgency.

Impact	Description
Critical	Exploitation will severely impact the service. Whereby it could halt business operations and/or allow an attacker to read or write arbitrary resources (including but not limited to the file system, registry, network, etc.).
High	Impact of finding identified may result in significant disruption to application/infrastructure operation e.g. access to higher privilege functionality, unauthorised access or compromise at the Operating System level.
Medium	Exploitation may not result in immediate compromise or may require taking advantage of other issues e.g. insecure password policy or access to non-sensitive data.
Low	Issues will not allow for compromise of the application and may not be exploitable at present e.g. alignment with best practices, logon practices that may reduce accountability.
Info	Issue does not pose a security risk e.g. intended functionality not working as planned, testing limitations, etc.

A "Difficulty to exploit" rating which estimates the level of effort and knowledge required for a potential intruder to take advantage of the issue (with High identifying complexity

Difficulty to exploit	Description
High	Vulnerability will likely only be exploited by expert level attacker. May require development of specific code and/or be time consuming.
Medium	Exploitation may be achieved by intermediate level intruder – customisation of existing code may be required.
Low	Automated tools and/or public documentation exists that will make exploitation trivial.

6.2. CVSS VERSION 3.1 DESCRIPTION

The Common Vulnerability Scoring System (CVSS) provides an open framework for communicating the characteristics and impact of IT vulnerabilities. Its quantitative model ensures consistent and reproducible metrics generated based on general characteristics of vulnerabilities.

The current version of the CVSS framework is version 3.1. In this version, the complete measure is composed from three independent scores – Base, Temporal and Environmental.

The Base score describes the fundamental characteristics of the vulnerability that are constant over time and environments.

The Temporal score describes the characteristics that change over time due to events external to the vulnerability.

The Environmental score describes the characteristics that depend on the particular environment of the affected systems and their position within the particular organisation

BDO typically does not have a complete view of the systems it is assessing and is only able to provide the Base score that does not depend on environmental and temporal factors. Nevertheless, there are several public web resources such as NVD that provide comprehensive CVSSv3.1 calculators.

6.3. SEVERITY RATING

As highlighted in the previous section, BDO is typically not the business owner of the systems under assessment and is not commissioned to perform a detailed risk assessment. Vulnerabilities are assigned a Base score to provide augmented granularity over qualitative rankings, improve consistency across reports and allow for severity comparison of vulnerabilities from BDO reports and from other sources. If the Environmental or Temporal score is required for internal prioritisation, please refer system owners to any of the CVSSv3.1 calculators or contact BDO for an in-depth risk assessment.

In addition to the numeric CVSS scores, BDO has traditionally assigned vulnerabilities qualitative 'Risk Grading' rankings of "Low," "Medium," and "High". The table below explains the relationship between these rankings and CVSS.

Level	Risk Rating	CVSS Base score range
1	Low	0.0 - 3.9
2	Medium	4.0 - 6.9
3	High	7.0 - 8.9
3	Critical	9.0 - 10.0

6.4. OWASP VULNERABILITY CATEGORISATION

OWASP Vulnerability Category	Description
A1 - Injection	Injection flaws, such as SQL injection, LDAP injection, and CRLF injection, occur when an attacker sends untrusted data to an interpreter that is executed as a command without proper authorization.
A2 - Broken Authentication and Session Management	Incorrectly configured user and session authentication could allow attackers to compromise passwords, keys, or session tokens, or take control of users' accounts to assume their identities.
A3 - Sensitive Data Exposure	Applications and APIs that don't properly protect sensitive data such as financial data, usernames and passwords, or health information, could enable attackers to access such information to commit fraud or steal identities.
A4 - XML External Entity	Poorly configured XML processors evaluate external entity references within XML documents. Attackers can use external entities for attacks including remote code execution, and to disclose internal files and SMB file shares.
A5 - Broken Access Control	Improperly configured or missing restrictions on authenticated users allow them to access unauthorized functionality or data, such as accessing other users' accounts, viewing sensitive documents, and modifying data and access rights.
A6 - Security Misconfiguration	This risk refers to improper implementation of controls intended to keep application data safe, such as misconfiguration of security headers, error messages containing sensitive information (information leakage), and not patching or upgrading systems, frameworks, and components.
A7 - Cross-Site Scripting	Cross-site scripting (XSS) flaws give attackers the capability to inject client-side scripts into the application, for example, to redirect users to malicious websites.

OWASP Vulnerability Category	Description
A8 - Insecure deserialization	Insecure deserialization flaws can enable an attacker to execute code in the application remotely, tamper or delete serialized (written to disk) objects, conduct injection attacks, and elevate privileges.
A9 - Using Components With Known Vulnerabilities	Developers frequently don't know which open source and third-party components are in their applications, making it difficult to update components when new vulnerabilities are discovered. Attackers can exploit an insecure component to take over the server or steal sensitive data.
A10 - Insufficient Logging and Monitoring	The time to detect a breach is frequently measured in weeks or months. Insufficient logging and ineffective integration with security incident response systems allow attackers to pivot to other systems and maintain persistent threats.

7. METHODOLOGY

7.1. BDO METHODOLOGY

To facilitate the provision of this service to our clients, we have designed an approach that identifies the most serious risks and security flaws first and then focuses on less obvious areas as the project proceeds. This can be illustrated by the onion skin model.

Our model illustrates how we first test the client network for vulnerabilities from the outside. Initially, we will conduct this test assuming the point of view of an uninformed attacker. We then gradually move on until we assume the role of a trusted user of the network trying to access an unauthorised resource or service. The following list gives some more detail as to the specifics of each level.

Layer 1
External penetration testing (naive hacker)

- Establish whether unauthorised logical access can be gained via the external network interfaces by a 'naive' hacker who has limited and/or no previous knowledge of your network.

Layer 2
External penetration testing (supplier/customer level access)

- Establish whether unauthorised logical access can be gained, via external network components by a hacker who has the same level of access as your customers and suppliers, to the target production environment and other key systems.

Layer 3
Internal penetration testing (unauthorised user)

- Ascertain whether unauthorised access can be gained via internal penetration and audit testing of your systems by exploiting loopholes in your networks services and resources.
- Determine whether it is possible to manipulate key controls implemented for the protection of your system(s).
- Assess whether existing procedures for responding to such a breach of security are adequate and effective.
- Assess the security of certain sensitive servers and workstations.

Layer 4
Firewall and security systems review

- Analyse the effectiveness of the policies employed by your firewalls and the infrastructure in place for administration.
- Review the operating system configuration for a secure implementation.
- Review your procedures and processes for monitoring and reporting of incidents on the firewall.
- Review network and host security components, for example, IDS.

8. APPENDIX A - TOOLS USED

Penetration testing typically utilises a combination of manual and automated testing. The following is a list of the most relevant tools used during this test:

Name	Description
Nessus Professional	Vulnerability scanner
Burpsuite Professional	Intercepting proxy server
SSLscan	SSL cipher suite scanner
NMAP	Network discovery tool and port scanner
OS Utilities	Multiple Linux and MS-Windows operating system utilities such as ping
Wireshark	A network traffic capturing tool

BDO DIGITAL

Tel: 212-885-8000
Fax: 212-697-1299
www.bdo.com/digital

100 Park Avenue
10th Floor
New York, NY 10017